



Compliance Readiness Guide for HIPAA Examinations

Health Insurance Portability and Accountability Act (HIPAA)

What HHS OCR auditors are actually looking for in HIPAA technology examinations and how to be ready before the notice arrives.

1. How OCR HIPAA Investigations and Audits Work

HHS Office for Civil Rights enforces HIPAA through several mechanisms. Understanding which type of review you face determines your response strategy:

- **Complaint Investigations:** Triggered by patient or employee complaints to OCR. The most common trigger for HIPAA enforcement. OCR investigates approximately 25,000 complaints per year.
- **Breach Investigations:** All breaches affecting 500 or more individuals trigger OCR investigation. Smaller breaches are investigated based on risk-based selection from the annual breach log.
- **Compliance Reviews:** OCR Phase 2 Audit Program conducts desk audits and on-site investigations selected based on risk criteria. Focus areas include risk analysis, risk management, and breach notification.
- **Corrective Action Plans:** If OCR finds HIPAA violations they may require a CAP with formal remediation commitments and OCR oversight for 1-3 years including monitoring and periodic reporting.
- **Civil Money Penalties:** OCR can impose penalties up to 1.9 million dollars per violation category per calendar year for willful neglect. Most organizations settle via Resolution Agreement before penalties are imposed.

2. OCR Audit Document Request — Technology Focus

OCR Phase 2 Audit Protocol defines specific document requests for covered entities and business associates. For technology governance these are the core requests:

- **Security Risk Analysis:** most recent, covering all ePHI environments, with identified risks and risk ratings.
- **Risk Management Plan:** documented plan to reduce identified risks to a reasonable level with implementation status.
- **Security Policies and Procedures:** all Security Rule required policies, current, dated, and signed.
- **Workforce Training Records:** Security and Privacy Rule training completion logs with dates and content covered.
- **Technical Safeguards Evidence:** encryption configurations, access control settings, and audit log configurations.
- **Breach Notification Records:** documentation of all breaches and reportable incidents, notification evidence, and low probability analysis where applicable.

3. OCR Examination Focus Areas — Technology

Based on OCR enforcement actions and Resolution Agreements, these are the highest-risk technology governance areas:

- **Security Risk Analysis:** The SRA is the first document OCR requests. Outdated SRA, incomplete SRA missing ePHI environments, and no SRA at all are the three most common HIPAA violations OCR cites.
- **Encryption:** Unencrypted portable devices containing ePHI remain the single most common source of HIPAA enforcement. OCR has levied penalties exceeding 500,000 dollars for single unencrypted laptop thefts.
- **Business Associate Agreements:** Missing BAAs with active vendors accessing ePHI, BAAs that predate the 2013 Omnibus Rule, and BAAs that do not cover the vendor actual ePHI activities.
- **Workforce Training:** No documented annual HIPAA training, training records that do not identify what was covered or when, and new employee training gaps.
- **Contingency Planning:** No tested backup and recovery procedure, disaster recovery plan that has never been tested, and no documentation of contingency plan review and update.

4. Responding to OCR Investigations

OCR investigations can be triggered by a complaint or breach notification. How you respond in the first 30 days significantly affects the outcome:

- **Acknowledge within the requested timeframe:** OCR sets a response deadline in the investigation notice. Missing this deadline is itself a compliance failure.
- **Engage HIPAA counsel:** for any OCR investigation, engage legal counsel experienced in HIPAA enforcement before submitting your first response.
- **Produce completely and accurately:** OCR will request specific documents. Produce everything requested. Do not redact non-privileged information.
- **Demonstrate good faith remediation:** OCR considers whether the organization is actively remediating identified deficiencies in settlement negotiations. Begin remediation before OCR requests it.
- **Corrective Action Plan negotiation:** if OCR identifies violations you will negotiate a CAP. The scope of monitoring and the settlement amount are both negotiable with experienced counsel.

5. Building OCR Examination-Ready Documentation

The organizations that perform best in OCR investigations maintain documentation continuously:

- **Current SRA:** Updated within the past 12 months or after any material change to operations, technology, or environment. Scope covers all ePHI with no gaps.
- **Policy Currency:** All Security Rule required policies current, signed, and reflecting actual operations. No policies that have not been reviewed since implementation.
- **Evidence of Operation:** Policies must be accompanied by evidence of implementation including access logs, training records, backup test results, and audit log samples.
- **Incident Documentation:** Complete log of all security incidents including those determined not to be reportable breaches. The determination must be documented as your defense if OCR investigates.

6. HIPAA Compliance Readiness Checklist

Before an OCR investigation or audit, confirm you can produce within 24 hours:

- Current Security Risk Analysis updated within prior 12 months with all ePHI environments covered
- Risk management plan with documented remediation status for all identified risks
- All Security Rule required policies: current, signed, and reflecting actual operations
- Workforce training records: annual completion logs with dates and content for all workforce members
- BAA inventory: complete list of all BAAs with executed current BAAs
- Technical safeguards evidence: encryption configs, access control reports, and audit log samples
- Breach and incident log for all incidents for prior 6 years with disposition documentation
- Contingency plan test results: backup restore test and DR test from prior 12 months

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/healthcare

Call us: (877) 945-7177